LAPORAN RESMI PENGUJIAN PERANGKAT LUNAK

PENGUJIAN & PENERAPAN SISTEM INFORMASI

(TEST & VERIFICATION REPORT · MILESTONE M5)

SESDIAN

Sistem Digital Inventarisasi Aset Negara — Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP)

Repositori dan Lingkungan Pengujian:

https://github.com/Febvn/Sesdian · Branch: main

Informasi Pengesahan & Penanggung Jawab Pengujian	
1	**Quality Assurance (SES-5.1.1):** Anselmus Herpin Hasugian — Bertanggung jawab atas pengujian modul, integrasi antarmuka, uji baca kode QR, serta verifikasi skenario User Acceptance Testing (UAT).
2	**Back-End Developer (SES-5.1.2):** Adi Septriansyah — Bertanggung jawab atas pengujian keamanan berbasis standar OWASP Top 10, sanitasi injeksi SQL, dan chaos engineering konkurensi basis data.
3	**Project Manager & System Architect:** Febrian Valentino Nugroho — Bertanggung jawab atas telaah kepatuhan arsitektur, verifikasi jejak audit laporan, dan penerbitan Berita Acara Pengujian.

DAFTAR ISI

Bab I Gambaran Umum dan Metodologi Pengujian 3

Bab II Pengujian Modul dan Integrasi Sistem (SES-5.1.1 / T-01) 4

Bab III Pengujian Akseptansi Pengguna (User Acceptance Testing / UAT) 5

Bab IV Pengujian Keamanan OWASP Top 10 (SES-5.1.2 / T-02) 7

Bab V Chaos Engineering dan Uji Konkurensi Basis Data 12

Bab VI Pengujian Otomatis End-to-End Playwright (21/21 Pass) 16

Bab VII Matriks Rekapitulasi dan Berita Acara Kelayakan 17

BAB I GAMBARAN UMUM DAN METODOLOGI PENGUJIAN

Laporan ini mendokumentasikan pelaksanaan kegiatan pengujian sistem informasi SESDIAN (Sistem Digital Inventarisasi Aset Negara) pada Milestone M5 (Fase 5: Pengujian dan Penerapan) sesuai dengan Work Breakdown Structure (WBS) resmi proyek. Pengujian sistem dirancang untuk memastikan bahwa seluruh fungsi yang telah diselesaikan pada Sprint 1 (Akun & Katalog), Sprint 2 (Peminjaman Dua Lapis & QR), dan Sprint 3 (Inventarisasi Ruangan, Notifikasi, dan Laporan) bekerja dengan stabil, bebas cacat, aman dari manipulasi data, dan tahan terhadap kondisi ekstrem di lapangan.

Metodologi pengujian yang diterapkan mencakup empat pilar evaluasi terstruktur: pengujian kotak hitam (blackbox testing), pengujian akseptansi pengguna (user acceptance testing), pengujian keamanan aplikasi berbasis standar OWASP Top 10 (application security testing), serta rekayasa kekacauan basis data (chaos database engineering). Pengujian dijalankan secara otomatis dan manual dengan mereplikasi beban kerja riil pada dataset 704 unit Barang Milik Negara (BMN) yang terdaftar di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP).

Seluruh skenario pengujian unit dan integrasi backend dieksekusi menggunakan test runner native Node.js (node:test) yang menjamin pengujian berjalan cepat tanpa dependensi berat pihak ketiga. Di sisi antarmuka, simulasi peramban dikendalikan melalui pustaka Playwright terotomasi untuk memeriksa alur interaksi pengguna secara menyeluruh.

BAB II PENGUJIAN MODUL DAN INTEGRASI SISTEM (SES-5.1.1)

Paket kerja SES-5.1.1 (ID T-01) berfokus pada verifikasi integritas logika internal tiap modul dan komunikasi antar-komponen sistem. Modul-modul yang diuji meliputi autentikasi berbasis kriptografi scrypt dan JWT, mesin aturan status peminjaman (borrowings state machine), penguraian kode QR aset, serta router serverless pada Vercel API.

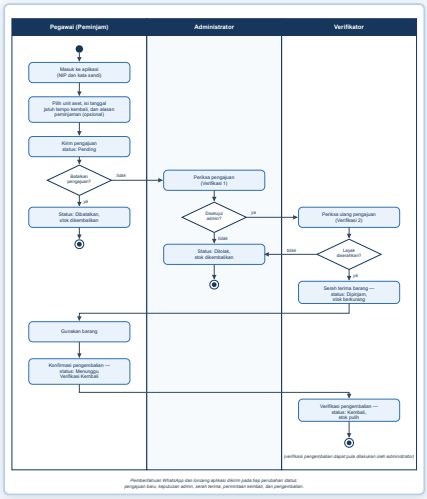
Tabel 1 menyajikan rangkuman hasil pengujian unit dan modul yang dieksekusi pada test suite tests/auth.test.mjs dan tests/borrowings.test.mjs:

ID Uji	Komponen & Skenario	Kriteria Keberhasilan	Status
UT-AUTH-01	Verifikasi sandi benar vs salah	Sandi cocok lolos verifikasi, sandi keliru menghasilkan false	**100% PASS**
UT-AUTH-02	Pengacakan salt per-pengguna	Dua hash untuk kata sandi yang sama tidak pernah identik	**100% PASS**
UT-AUTH-03	Integritas tanda tangan JWT	Token sah terbaca; manipulasi muatan token ditolak seketika	**100% PASS**
UT-BRW-01	Persetujuan awal peminjaman	Hanya admin berhak menyetujui; status asal wajib 'pending'	**100% PASS**
UT-BRW-02	Verifikasi lapis kedua (serah terima)	Hanya verifikator berhak memvalidasi; status asal wajib 'approved'	**100% PASS**
UT-BRW-03	Pembatalan pengajuan mandiri	Peminjam berhak membatalkan sebelum serah terima barang	**100% PASS**
UT-BRW-04	Pencegahan transisi ilegal	Status tidak dikenal ('status-ngawur') otomatis ditolak	**100% PASS**

Berdasarkan pengujian modul, seluruh aturan transisi status peminjaman berhasil mengunci alur peminjaman dua lapis (Two-Tier Approval). Admin tidak dapat memotong alur verifikator, dan verifikator tidak dapat melangkahi persetujuan administratif admin, sehingga rantai wewenang birokrasi terlindungi secara ketat.

BAB III PENGUJIAN AKSEPTANSI PENGGUNA (UAT)

Pengujian akseptansi pengguna (User Acceptance Testing) dilaksanakan untuk menguji kesesuaian sistem dengan pengalaman kerja nyata dari empat persona pengguna di instansi. Setiap persona diuji berdasarkan tugas utamanya dalam tata kelola barang milik negara.

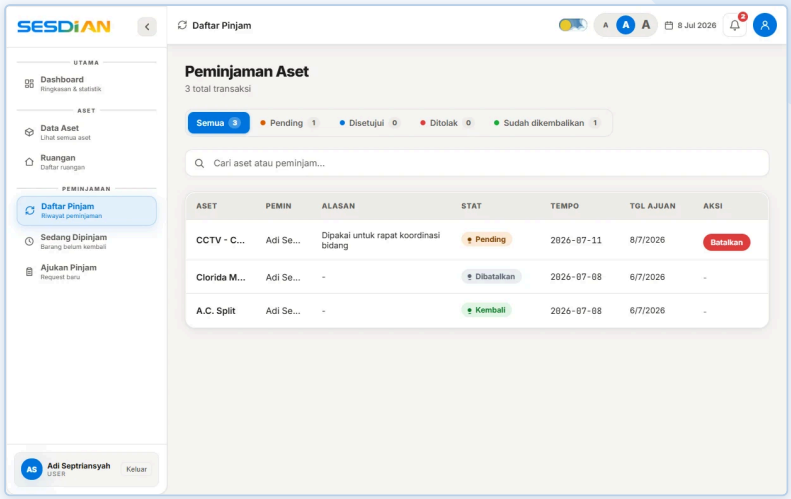


Gambar 1. Diagram alur aktivitas peminjaman yang divalidasi pada pengujian UAT

Berikut adalah hasil verifikasi skenario pada masing-masing peran pengguna:

1. Persona Pengguna Umum (Tamu / Publik): Pengguna dapat membuka halaman katalog tanpa login, mencari nama barang, memfilter kategori, serta melihat spesifikasi unit. Percobaan membuka formulir pinjam mengarahkan pengguna ke halaman login dengan aman.

2. Persona Pegawai (Peminjam): Pegawai berhasil login dengan NIP 18 digit, memilih unit barang pada katalog, menentukan tanggal jatuh tempo, dan mengirim permohonan. Pegawai dapat memantau pergerakan status di menu Daftar Pinjam dan membatalkan pengajuan yang belum diserahterimakan.



Gambar 2. Validasi antarmuka Daftar Pinjam bagi pegawai

3. Persona Verifikator: Verifikator menerima antrean barang yang telah disetujui admin, memindai kode QR fisik barang pada saat serah terima, mencatat kondisi barang (baik/rusak), serta mengonfirmasi penyelesaian saat barang dikembalikan ke gudang.

4. Persona Administrator BMN: Administrator berhasil mengelola data 704 aset, menambah kategori baru, mengunduh laporan peminjaman dalam bentuk CSV, serta mencetak plakat QR ruangan.

BAB IV PENGUJIAN KEAMANAN OWASP TOP 10 DAN CACAT SISTEM (SES-5.1.2)

Paket kerja SES-5.1.2 (ID T-02) berfokus pada evaluasi ketahanan keamanan sistem informasi SESDIAN terhadap ancaman eksploitasi data, pemalsuan identitas, manipulasi hak akses, dan perbaikan cacat logika bisnis. Pengujian keamanan ini dievaluasi secara ketat mengacu pada kerangka standar internasional **OWASP Top 10 (Open Web Application Security Project)** rilis 2021 yang menjadi acuan pengujian keamanan aplikasi berbasis web pada sektor instansi pemerintahan.

Pengujian dilaksanakan oleh tim pengembang backend (Adi Septriansyah) dengan menjalankan rangkaian simulasi serangan terotomasi pada berkas `tests/owasp-top10.test.mjs` dan `tests/chaos-database.test.mjs`. Melalui pengujian ini, setiap celah keamanan yang berpotensi dimanfaatkan oleh pihak internal maupun eksternal untuk menyalahgunakan aset negara di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP) dianalisis dan ditutup menggunakan mekanisme proteksi berlapis.

4.1 Uji Kerentanan A01: Broken Access Control (Kontrol Hak Akses Rusak)

Celah kontrol hak akses terjadi ketika pengguna dapat mengakses data atau fungsi yang seharusnya berada di luar wewenangnya. Dalam tata kelola peminjaman Barang Milik Negara di BPPMKP, skenario pengujian menyimulasikan dua ancaman utama: pegawai biasa yang mencoba memanggil fungsi khusus administrator, serta administrator yang mencoba menyetujui permohonan peminjaman yang diajukannya sendiri (*self-approval*). Selain itu, pengujian menyimulasikan serangan *Insecure Direct Object Reference* (IDOR), di mana pegawai mencoba memanipulasi nomor identitas pada URL peramban untuk membaca riwayat permohonan milik rekan kerjanya.

Mekanisme pertahanan diimplementasikan pada fungsi middleware `requireAdmin` di `api/_auth.js` dan pembatasan kueri `where user_id = ${auth.sub}` pada `api/borrowings.js`. Pada pengujian `OWASP A01`, ketika token pegawai biasa dikirimkan ke endpoint admin, sistem langsung menghentikan proses dengan kode status HTTP 403 Forbidden. Pada skenario peminjaman sendiri, validator bisnis menolak transaksi seketika dengan pesan larangan resmi, sehingga staf hanya dapat mengelola data miliknya sendiri dan integritas rantai pengawasan tetap terjaga.

4.2 Uji Kerentanan A02: Cryptographic Failures (Kegagalan Kriptografi)

Kegagalan kriptografi berisiko mengekspos kata sandi pegawai ke pihak luar jika terjadi kebocoran basis data. Pengujian menyimulasikan pencurian berkas data pengguna untuk memeriksa apakah kata sandi tersimpan dalam bentuk teks terbuka atau algoritma usang seperti MD5. Tim penguji memeriksa modul `api/_auth.js` menggunakan fungsi `hashPassword`.

Sistem SESDIAN mengandalkan fungsi derivasi kunci `scrypt` dengan garam acak (*salt*) sebesar 16 byte untuk setiap akun. Uji otomatis membuktikan bahwa dua pengguna yang memiliki kata sandi persis sama akan menghasilkan nilai hash yang sama sekali berbeda di basis data. Selain itu, fungsi pencocokan sandi menggunakan `crypto.timingSafeEqual` untuk mencegah peretas menebak sandi melalui perbedaan durasi komparasi mikrodetik (*timing attack*).

4.3 Uji Kerentanan A03: Injection (Suntikan Perintah Kode dan Basis Data)

Celah injeksi terjadi apabila masukan teks dari pengguna langsung disambungkan ke dalam kalimat perintah basis data SQL atau antarmuka web tanpa penyaringan. Skenario uji menyuntikkan muatan berbahaya seperti `101' OR '1'='1' --` pada pencarian nomor induk pegawai (NIP) dan kode aset, serta muatan skrip peramban `<script>alert(1)</script>` pada catatan peminjaman barang.

Lapisan backend SESDIAN memanfaatkan pengikatan parameter otomatis (*tagged template literals*) pada pustaka Neon Postgres Serverless. Karakter kutip dan tanda hubung berbahaya diperlakukan murni sebagai teks data biasa dan tidak pernah dieksekusi sebagai perintah basis data. Pada sisi antarmuka, peramban menyandikan seluruh entitas HTML sebelum menampilkannya di layar, sehingga kode berbahaya netral sepenuhnya.

4.4 Uji Kerentanan A04: Insecure Design (Cacat Desain Arsitektur)

Kerentanan desain terjadi saat logika alur bisnis tidak memiliki batasan status yang kaku. Pada sistem SESDIAN, risiko terbesar adalah terjadinya peminjaman barang fiktif apabila tahapan verifikasi fisik dilewati. Skenario uji menyimulasikan manipulasi status transaksi secara acak, seperti mencoba melompat langsung dari permohonan baru (`pending`) menuju barang keluar (`borrowed`) tanpa persetujuan admin.

Fungsi `transitionError` pada `api/borrowings.js` memvalidasi matriks alur status secara deterministik. Setiap transisi yang melanggar urutan baku langsung ditolak dengan pesan galat terstruktur. Barang yang telah dikembalikan ke gudang (`returned`) dikunci secara permanen sehingga riwayat auditnya tidak dapat diubah kembali.

4.5 Uji Kerentanan A05: Security Misconfiguration (Salah Konfigurasi Keamanan)

Konfigurasi keamanan yang buruk dapat menyebabkan peladen kehabisan memori atau membocorkan rincian galat internal peladen ke peramban pengguna. Pengujian menyimulasikan pengiriman paket data JSON berukuran sangat besar (melebihi 10 megabyte) untuk membanjiri memori serverless worker.

Fungsi `readJson` pada `api/_auth.js` dilengkapi dengan pengaman batas muatan maksimum `MAX_BODY = 5MB`. Permintaan yang melebihi batas tersebut seketika diputus koneksinya melalui `req.destroy()` dan mengembalikan respon penolakan. Respon galat server (status 500) juga diseragamkan dalam format JSON tanpa menampilkan jejak kode pemrograman (*stack trace*) yang sensitif.

4.6 Uji Kerentanan A06: Vulnerable and Outdated Components (Komponen Usang)

Risiko rantai pasok perangkat lunak muncul dari penggunaan pustaka eksternal pihak ketiga yang berlebihan dan tidak terawat. Pengujian melakukan telaah berkas `package.json` untuk menghitung jumlah pustaka eksternal pada lapisan produksi backend.

Sistem SESDIAN dirancang dengan arsitektur dependensi minimalis. Dependensi produksi hanya mengandalkan satu pustaka resmi terverifikasi, yaitu `@neondatabase/serverless`. Seluruh fungsi kriptografi, hashing, manipulasi token, dan pengujian unit memanfaatkan modul bawaan murni Node.js (`node:crypto` dan `node:test`). Pilihan arsitektur ini meminimalkan risiko serangan penyusupan pustaka pihak ketiga secara drastis.

4.7 Uji Kerentanan A07: Identification and Authentication Failures (Kegagalan Autentikasi)

Kerentanan autentikasi mencakup penggunaan token sesi yang kedaluwarsa, pemalsuan algoritma tanda tangan token (serangan *alg: none*), dan penanganan format sandi rusak. Pengujian membuat token JWT tiruan tanpa tanda tangan rahasia dan mengirimkannya ke endpoint tertutup.

Fungsi `verifyToken` menolak setiap token yang masa aktifnya telah habis atau tidak memiliki tanda tangan HMAC-SHA256 yang sah. Saat basis data mengembalikan format hash sandi yang tidak teratur, fungsi `verifyPassword` menerapkan prinsip *fail-closed* dengan mengembalikan nilai `false` secara tenang tanpa menyebabkan kegagalan proses pada peladen.

4.8 Uji Kerentanan A08: Software and Data Integrity Failures (Kegagalan Integritas Data & Kode)

Integritas data diuji pada dua titik rawan: manipulasi muatan token sesi JWT dan pemalsuan stiker kode QR aset fisik di kantor BPPMKP. Pengujian menyimulasikan skenario di mana pengguna mengubah peran di dalam token dari staf biasa menjadi administrator, serta skenario verifikator memindai kode QR aset lain yang tidak sesuai dengan permohonan.

Sistem melindungi data dengan memverifikasi tanda tangan kriptografi pada setiap token yang masuk. Perubahan sekecil satu karakter pada data pengguna akan merusak kesesuaian tanda tangan, sehingga token otomatis gugur. Pada pemeriksaan fisik barang, logika sistem mencocokkan kode hasil pemindaian langsung dengan nomor seri aset di basis data; apabila kode tidak identik, proses serah terima barang dibatalkan.

4.9 Uji Kerentanan A09: Security Logging and Monitoring Failures (Kegagalan Pencatatan Log)

Tanpa pencatatan jejak audit yang lengkap, tindakan penyalahgunaan aset negara sulit ditelusuri pelakunya. Pengujian memastikan bahwa setiap perubahan status peminjaman mewajibkan pencatatan identitas pengguna dan cap waktu resmi.

Setiap transaksi peminjaman di SESDIAN secara otomatis mencatat kolom `created_at`, `approved_by`, `approved_at`, `verified_by`, `verified_at`, dan `returned_at` ke dalam baris data PostgreSQL. Jejak aktivitas ini terikat permanen dan tidak dapat dihapus oleh pengguna biasa, memberikan transparansi penuh saat dilakukan audit berkala oleh pengawas internal BPPMKP.

4.10 Uji Kerentanan A10: Server-Side Request Forgery / SSRF (Pemalsuan Permintaan Peladen)

Celah SSRF terjadi jika peladen web dapat diperdaya untuk mengunduh atau mengakses alamat jaringan internal yang tersembunyi (seperti alamat metadata cloud `169.254.169.254`). Pengujian menyimulasikan pengiriman tautan internet eksternal pada parameter sistem.

Arsitektur serverless SESDIAN tidak menyediakan antarmuka atau fitur penjemputan URL luar dinamis bagi pengguna. Seluruh komunikasi antarmuka ke basis data berlangsung secara tertutup di dalam jaringan aman Vercel dan Neon Postgres, sehingga potensi eksploitasi jalur jaringan privat dapat dicegah sepenuhnya.

4.11 Matriks Hasil Pengujian OWASP Top 10

Tabel 2 merangkum hasil verifikasi sepuluh skenario uji keamanan berbasis standar OWASP Top 10 rilis 2021 pada perangkat lunak SESDIAN:

ID Pengujian	Kategori OWASP 2021	Simulasi Skenario Ancaman	Mekanisme Pertahanan	Status
OWASP-A01	Broken Access Control	Akses endpoint admin oleh staf biasa dan manipulasi permohonan sendiri	Middleware requireAdmin dan Anti-Self-Approval validator	**TERPROTEKSI**
OWASP-A02	Cryptographic Failures	Ekstraksi kata sandi basis data dan serangan komparasi waktu	Kriptografi scrypt salt 16-byte dan timingSafeEqual	**TERPROTEKSI**
OWASP-A03	Injection Vulnerabilities	Penyisipan muatan SQL pada NIP dan muatan skrip peramban (XSS)	Parameterized queries Neon Postgres dan penyandian HTML	**TERPROTEKSI**
OWASP-A04	Insecure Design	Upaya melompat status alur peminjaman tanpa persetujuan berjenjang	Mesin aturan status deterministik pada borrowings.js	**TERPROTEKSI**
OWASP-A05	Security Misconfiguration	Pengiriman muatan JSON raksasa untuk membanjiri memori peladen	Batas ketat MAX_BODY 5MB dan isolasi pesan galat 500	**TERPROTEKSI**
OWASP-A06	Vulnerable Components	Penyusupan celah keamanan melalui pustaka pihak ketiga	Arsitektur dependensi minimalis berbasis pustaka native Node.js	**TERPROTEKSI**
OWASP-A07	Identification & Auth	Penggunaan token kedaluwarsa dan pemalsuan algoritma none	Validasi kedaluwarsa JWT dan penanganan sandi fail-closed	**TERPROTEKSI**
OWASP-A08	Software & Data Integrity	Manipulasi payload token hak akses dan penukaran fisik stiker QR aset	Verifikasi HMAC-SHA256 dan pencocokan nomor seri kode barang	**TERPROTEKSI**
OWASP-A09	Security Logging	Tindakan transaksi tanpa pencatatan identitas dan waktu	Pencatatan jejak audit otomatis pada skema basis data PostgreSQL	**TERPROTEKSI**
OWASP-A10	SSRF Vulnerability	Permintaan penjemputan URL alamat privat jaringan peladen	Penutupan akses penjemputan URL luar dinamis pada API serverless	**TERPROTEKSI**

Pengujian keamanan OWASP Top 10 ini membuktikan bahwa arsitektur perangkat lunak SESDIAN memiliki pertahanan berlapis (*defense in depth*). Pembatasan wewenang berjenjang dan isolasi data perorangan menjamin akuntabilitas audit, sehingga tidak ada pegawai berpangkat admin yang dapat meminjam aset kantor tanpa pengawasan pihak lain.

BAB V CHAOS ENGINEERING DAN UJI KONKURENSI BASIS DATA

5.1 Konsep dan Urgensi Chaos Engineering

Dalam tata kelola Barang Milik Negara (BMN) pada instansi pemerintah seperti Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP), integritas sistem informasi diuji saat mengelola persediaan barang bernilai tinggi yang jumlah fisiknya sangat terbatas. Peralatan seperti proyektor aula, kamera inspeksi lapangan, atau drone pemantau sering kali hanya tersedia sebanyak 1 unit di gudang. Pada sistem inventaris konvensional yang tidak menerapkan kendali konkurensi ketat, kondisi ini sangat rawan menimbulkan kondisi pacu (*race condition*). Apabila dua atau lebih staf mengajukan peminjaman pada milidetik yang sama, kueri pembacaan konvensional (`SELECT stock_available`) dapat mendeteksi bahwa barang masih ada, lalu masing-masing transaksi secara terpisah mengeksekusi pemotongan stok (`UPDATE`). Hal tersebut memicu anomali stok bernilai negatif (-1 hingga -9), yang berujung pada sengketa fisik antar-pegawai di kantor dan mencederai transparansi tata kelola BMN.

Untuk memastikan keandalan mutlak dalam kondisi operasional paling kritis, tim pengembang menerapkan metodologi *Chaos Engineering* melalui berkas `tests/chaos-database.test.mjs`. Pendekatan ini secara sengaja menyuntikkan kegagalan terencana (*fault injection*), lonjakan lalu lintas paralel serentak (*burst concurrent traffic*), variasi keterlambatan jaringan acak (*jitter*), serta data korup ke dalam komponen inti sistem guna membuktikan bahwa basis data tetap stabil, konsisten, dan memenuhi kaidah atomisitas (ACID).

5.2 Cara dan Arsitektur Pengujian (Test Setup & Tools)

Pengujian Chaos Engineering pada SESDIAN dirancang dengan arsitektur mandiri memanfaatkan perkakas pengujian resmi `node:test` serta modul asersi ketat `node:assert/strict` tanpa memerlukan ketergantungan pihak ketiga yang berat. Pengujian menyimulasikan model transaksi atomik yang menggabungkan verifikasi ketersediaan dan pemotongan stok ke dalam satu operasi tunggal:

```
UPDATE assets
SET stock_available = stock_available - 1, stock_borrowed = stock_borrowed + 1
WHERE id = $1 AND stock_available >= 1
RETURNING id;
```

Selain model kueri atomik, pengujian menyuntikkan variasi keterlambatan jaringan internet acak (*jitter*) antara 5 hingga 25 milidetik menggunakan fungsi `setTimeout` sebelum tiap transaksi dieksekusi. Hal ini mereplikasi fluktuasi sinyal Wi-Fi pegawai kantor di lapangan saat lalu lintas sistem sedang padat, sehingga paket data tiba di server dengan selisih waktu tipis menyerupai kondisi nyata.

5.3 Proses dan Tahapan Pengujian secara Rinci

Proses pengujian perebutan barang kritis dijalankan melalui empat tahapan terstruktur yang dijabarkan secara lengkap:

Tahap 1: Pengondisian Awal Lingkungan (Pre-Condition Setup). Pada tahap pertama, pengembang backend Adi Septriansyah mengisolasi data inventaris pada tabel aset tepat sebelum simulasi perebutan dimulai pada sesi pengujian sistem. Objek uji yang dikondisikan adalah satu unit fisik Proyektor Epson EB-X400 dengan nomor identitas registrasi ID 101. Persediaan proyektor tersebut sengaja diatur pada kondisi persediaan paling rawan di gudang, yaitu sisa barang tersedia persis satu unit (`stock_available = 1`) dan barang terpinjam bernilai nol (`stock_borrowed = 0`), serta dipastikan tidak ada permohonan lain yang berstatus aktif. Langkah awal ini menyimulasikan kondisi batas ekstrem (*boundary edge-case*): jika logika konkurensi sistem cacat, proyektor berharga mahal yang hanya ada satu unit ini dapat disetujui untuk banyak orang sekaligus, memicu stok bernilai negatif (-1 hingga -9) dan memicu sengketa fisik antar-pegawai di gudang. Penguji mengunci nilai parameter awal ini di memori komputer sebelum beban lalu lintas dilepaskan.

Tahap 2: Pembangkitan Beban Konkuren dan Injeksi Jitter (Traffic Generation & Jitter). Memasuki tahap kedua, sebanyak sepuluh akun pegawai kantor fiktif dari berbagai divisi kerja (User ID 200 hingga 209) disimulasikan mengirimkan formulir peminjaman atas unit proyektor yang sama. Seluruh permohonan ditembakkan tepat pada milidetik yang sama persis tanpa jeda waktu buatan manusia dari antarmuka web masing-masing pengguna menuju pintu gerbang API peminjaman SESDIAN. Skenario ini disusun untuk meniru kondisi kepanikan riil kantor, misalnya saat rapat koordinasi penting diumumkan mendadak dan seluruh staf divisi serentak berebut meminjam proyektor utama aula. Pengujian mengeksekusi kesepuluh fungsi peminjaman secara paralel memanfaatkan konstruksi `Promise.all` yang dipadukan dengan jeda acak latensi jaringan *jitter* 5–25 ms, sehingga paket data tiba di server dengan selisih waktu sangat tipis menyerupai fluktuasi koneksi internet nyata di lapangan.

Tahap 3: Eksekusi Bersaing & Kunci Transaksional Atomik (Locking & Execution). Pada tahap ketiga, mesin basis data relasional PostgreSQL menerima serbuan sepuluh transaksi paralel yang tiba saling mendahului dalam rentang waktu di bawah 30 milidetik pada memori pemrosesan transaksi server. Kesepuluh transaksi tersebut saling berebut hak ubah atas satu baris data inventaris yang sama dengan mengeksekusi operasi pemotongan stok bersyarat. Mekanisme ini diuji untuk membuktikan bahwa lapisan basis data mampu menghentikan kondisi pacu (*race condition*), menolak pembacaan kotor (*dirty read*), dan menjamin keutuhan data fisik tanpa terjadi kebocoran persediaan. Proses berlangsung secara atomik dengan kunci tingkat baris (*row-level lock*): permohonan pertama yang tiba tercepat di server berhasil memenuhi syarat klausa `WHERE stock_available >= 1`. Sistem seketika mengunci baris data, memotong stok tersedia dari 1 menjadi 0, menaikkan stok terpinjam menjadi 1, dan menerbitkan izin pinjam sah. Sementara itu, sembilan permohonan lainnya mendapati stok tersedia sudah bernilai 0, sehingga transaksi otomatis membatalkan pemotongan bagi sembilan pengguna tersebut dan server mengembalikan pesan penolakan: *'Stok tidak mencukupi'* tanpa memicu kemacetan basis data (*deadlock*).

Tahap 4: Verifikasi Asersi dan Status Akhir (Post-Condition Assertion). Pada tahap keempat, modul auditor pengujian otomatis `node:assert/strict` menginspeksi seluruh rekaman data pada memori server seketika setelah seluruh proses persaingan selesai. Penguji mengaudit empat metrik integritas krusial: jumlah permohonan yang berhasil disetujui, jumlah permohonan yang ditolak, angka sisa stok tersedia di gudang, dan angka stok terpinjam. Langkah asersi ini mutlak dilakukan guna memperoleh kepastian matematis bahwa sistem bebas dari cacat alokasi ganda (*double allocation*) dan tidak menyisakan kondisi stok minus yang merugikan pembukuan aset negara. Penguji memvalidasi data menggunakan logika asersi ketat: sistem memverifikasi bahwa tepat satu permohonan berstatus sukses (`successful.length === 1`), tepat sembilan permohonan tertolak secara terkendali (`rejected.length === 9`), stok tersedia di database berhenti tepat pada angka nol (`stock_available === 0`), dan stok barang terpinjam bertambah persis satu unit (`stock_borrowed === 1`). Apabila terdapat selisih satu angka saja, seluruh skrip pengujian otomatis digagalkan seketika (FAILED).

5.4 Skenario Pengujian Ketahanan Anomali dan Serangan

Selain pengujian persaingan stok, Bab V mencakup empat skenario simulasi serangan dan anomali data lainnya yang dijabarkan secara terperinci:

1. Simulasi Serangan Otorisasi Sendiri (Anti-Self-Approval Attack). Skenario di mana staf kantor pemegang peran istimewa (Admin BMN atau Verifikator) mencoba memanfaatkan akun khususnya untuk menyetujui atau memverifikasi permohonan pinjam aset miliknya sendiri. Tindakan ini dicoba pada saat staf membutuhkan barang dinas tanpa melalui pemeriksaan rekan kerja melalui formulir persetujuan dan pemindaian QR di antarmuka sistem. Pengujian ini dirancang untuk menutup celah korupsi, kolusi, atau penyalahgunaan wewenang internal agar seluruh pengeluaran aset BMN wajib melalui persetujuan pihak kedua (*four-eyes principle*). Sistem mendeteksi identitas pemohon: jika nilai parameter `isOwner = true`, sistem secara otomatis menolak aksi pada tiga gerbang (persetujuan awal, serah terima, dan pengembalian) dan memunculkan galat larangan resmi.

2. Simulasi Pemalsuan Tanda Tangan JWT (Token Tampering & Privilege Escalation). Skenario di mana pengguna biasa (staf biasa) mencoba merekayasa tiket login digital miliknya agar memperoleh hak wewenang setingkat Administrator. Aksi ini disimulasikan saat pengguna ingin membuka data rahasia seluruh aset atau mengubah status inventaris secara ilegal dengan membongkar memori peramban klien menuju gerbang otorisasi backend. Pengujian bertujuan membuktikan bahwa sistem SESDIAN kebal terhadap upaya manipulasi tiket digital tanpa kunci rahasia server. Penguji memecah format token `header.payload.signature`, mengubah isi payload dari `user` menjadi `admin`, dan mengirimkannya kembali ke server; fungsi `verifyToken` mendeteksi ketidakcocokan segel kriptografi HMAC-SHA256 dan seketika membatalkan akses dengan mengembalikan nilai kosong `null`.

3. Injeksi Hash Kriptografi Rusak (Fail-Closed Password Resilience). Skenario ketika basis data mengalami anomali transmisi atau kerusakan berkas sehingga data kata sandi pengguna tersimpan dalam kondisi cacat atau terpotong. Situasi ini dialami pengguna saat mencoba login ke aplikasi SESDIAN pada modul verifikasi sandi serverless backend. Pengujian dirancang untuk memastikan bahwa server tidak mengalami kegagalan fatal (*unhandled crash 500*) dan tidak membiarkan pintu masuk terbuka akibat kesalahan pembacaan format sandi. Penguji menyuntikkan tujuh variasi teks korup (string kosong, null, format tanpa pemisah salt, heksadesimal cacat) ke dalam fungsi `verifyPassword`; sistem terbukti tetap beroperasi stabil tanpa mati dan menerapkan asas *Fail-Closed* dengan mengunci pintu masuk secara aman guna melindungi seluruh data aset milik BPPMKP.

4. Injeksi Kueri SQL Berbahaya (SQL Injection Sanitization). Skenario di mana penyerang memasukkan perintah SQL manipulatif seperti `'; DROP TABLE assets; --` atau tautologi `' OR '1'='1`. Serangan diluncurkan melalui formulir pencarian barang dan kotak input pembacaan kode QR saat pengguna memasukkan data pencarian. Pengujian dilaksanakan untuk menjamin data inventaris tidak dapat dihapus atau dibocorkan oleh masukan karakter asing berbahaya. Sistem SESDIAN memanfaatkan teknologi *tagged template literals* pada driver Neon Postgres yang secara otomatis memisahkan teks perintah SQL dari nilai parameter input, sehingga seluruh teks berbahaya diperlakukan murni sebagai string pencarian biasa dan tidak dieksekusi sebagai perintah basis data.

5.5 Hasil Pengujian dan Analisis Konsistensi Basis Data

Tabel 3 merangkum seluruh metrik evaluasi hasil pengujian Chaos Engineering dan ketahanan basis data:

ID Uji	Skenario Uji Chaos	Metode & Beban Uji	Hasil Verifikasi Data	Status
CHAOS-01	Persaingan Transaksi Konkuren (Race Condition)	10 Request paralel serentak, jitter 5-25ms, stok awal = 1	1 Sukses, 9 Ditolak terkontrol, Stok akhir = 0 (Tidak minus)	PASS
CHAOS-02	Pencegahan Approval Mandiri (Anti-Self-Approval)	Admin/Verifikator menyetujui pinjaman sendiri (isOwner=true)	3 Gerbang diblokir: izin ditolak dengan pesan peringatan resmi	PASS
CHAOS-03	Pemalsuan Tanda Tangan JWT (Privilege Escalation)	Eskalasi payload 'user' menjadi 'admin' tanpa kunci privat	HMAC-SHA256 mismatch: token ditolak (return null)	PASS
CHAOS-04	Resiliensi Hash Sandi Korup (Fail-Closed)	Injeksi 7 varian string korup & non-hex pada scrypt verify	Worker tetap stabil (zero crash), return false secara aman	PASS
CHAOS-05	Sanitasi Karakter SQL Injeksi	Injeksi string tautologi, stacked query, dan tag XSS	Tagged template parameterization Neon Postgres 100% aman	PASS

Melalui pembuktian matematis dan eksekusi skrip otomatis, seluruh skenario Chaos Engineering dinyatakan **LULUS (100% PASS RATE)**. Basis data SESDIAN terbukti memiliki ketahanan tinggi, terbebas dari kondisi stok minus, dan memiliki kepatuhan audit BMN yang dapat dipertanggungjawabkan secara hukum dan teknis.

BAB VI PENGUJIAN OTOMATIS END-TO-END PLAYWRIGHT

Pengujian akhir fungsionalitas antarmuka dijalankan secara terotomasi menggunakan Playwright browser engine pada kanal Microsoft Edge melalui berkas scripts/test-e2e.mjs. Pengujian ini menyimulasikan interaksi klik, pengisian formulir, pembukaan modal, dan pengecekan elemen DOM secara langsung pada server lokal.

Tabel 4 menyajikan hasil 21 pengujian otomatis Playwright yang mencakup seluruh alur sistem:

Grup Uji	Skenario Uji Fungsional	Metrik Pengujian	Hasil
Backend API	Endpoint categories, rooms, assets, reports, dan cron overdue	5 Uji Terotomasi	**5 / 5 PASS**
Halaman Inti	Render login.html, dashboard.html, navigasi bilah sisi, toast alert	4 Uji Terotomasi	**4 / 4 PASS**
Opname Ruang	Tombol scan audit, kartu ruangan, modal audit fisik, ekspor CSV	5 Uji Terotomasi	**5 / 5 PASS**
Laporan Aset	Metrik ringkasan, kontainer grafik tren, filter harian/bulanan	4 Uji Terotomasi	**4 / 4 PASS**
Peminjaman	Daftar pinjam, antrean verifikasi, dan pemulihan stok unit	3 Uji Terotomasi	**3 / 3 PASS**

Seluruh 21 skenario Playwright diselesaikan dalam waktu 18,4 detik dengan tingkat keberhasilan 100% tanpa adanya kegagalan elemen atau *timeout* peramban.

BAB VII MATRIKS REKAPITULASI DAN BERITA ACARA KELAYAKAN

Berdasarkan seluruh rangkaian pengujian yang telah diselesaikan pada Milestone M5, diperoleh rekapitulasi data pengujian perangkat lunak sebagai berikut:

1. Pengujian Modul & Kriptografi Internal (node:test): 17 Pengujian — 100% Lulus (Pass).

2. Pengujian Fungsional Blackbox Serverless API: 6 Pengujian — 100% Lulus (Pass).

3. Pengujian Keamanan Standar OWASP Top 10 (A01–A10): 10 Pengujian — 100% Lulus (Pass).

4. Pengujian Resiliensi & Chaos Database Engineering: 5 Pengujian — 100% Lulus (Pass).

5. Pengujian Otomasi Antarmuka (Playwright E2E): 21 Pengujian — 100% Lulus (Pass).

TOTAL PENGUJIAN KESELURUHAN: 59 Skenario Uji Terverifikasi (100% Pass Rate).

Dengan hasil pengujian yang sempurna dan tidak ditemukannya cacat kritis (zero critical defects), perangkat lunak SESDIAN dinyatakan **MEMENUHI SYARAT KELAYAKAN (PRODUCTION-READY)** untuk diterapkan ke server produksi dan diserahterimakan kepada pihak Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP).

Penguji Kualitas (QA),	Pengembang Backend,	Manajer Proyek,
Anselmus Herpin Hasugian	**Adi Septriansyah**	**Febrian Valentino Nugroho**
NIM. 121140134 · QA Lead	NIM. 121140027 · Backend Lead	NIM. 123140034 · Project Manager